

Hallinnollinen tietoturva-auditoinnin checklist

Tämä checklist on laadittu PK-yrityksen hallinnollisten tietoturvakäytäntöjen arviointia varten. Kysymykset perustuvat Traficom, ISO/IEC 27001/27002:n sekä NIST Cybersecurity Frameworkin suosituksiin. Checklistin avulla voidaan arvioida hallintaa, politiikkoja ja prosesseja, ja kirjata havaintoja.

Kategoria	Kysymys / tarkistettava asia	Viitekehys	Status (Kyllä / Ei / Osittain)	Kommentit
Tietoturvapolitiikka ja hallinto	Onko yrityksellä kirjallinen tietoturvapolitiikka?	ISO 27001, Traficom		
Tietoturvapolitiikka ja hallinto	Onko tietoturvapolitiikka päivitetty viimeisen 12 kk aikana?	ISO 27001		
Tietoturvapolitiikka ja hallinto	Onko vastuut ja roolit tietoturva-asioissa määritelty?	ISO 27001, NIST CSF		
Riskienhallinta	Onko yritys tehnyt tietoturvariskien arvioinnin?	ISO 27005, NIST CSF		
Riskienhallinta	Onko riskienhallintasuunnitelma dokumentoitu ja hyväksytty?	ISO 27001, NIST CSF		
Riskienhallinta	Päivitetäänkö riskiarviota säännöllisesti?	ISO 27001		
Henkilöstön koulutus ja ohjeistus	Toteutetaanko henkilöstölle säännöllistä tietoturvakoulutusta?	Traficom, NIST CSF		
Henkilöstön koulutus ja ohjeistus	Onko ohjeet phishing-/haittaohjelmatilanteissa olemassa?	Traficom, NIST CSF		
Henkilöstön koulutus ja ohjeistus	Tiedetäänkö kenelle raportoidaan tietoturvapoikkeamat?	Traficom, ISO 27001		
Käyttöoikeudet ja salasanaolitiikka	Onko käyttöoikeuksien hallinta dokumentoitu?	ISO 27002, NIST CSF		
Käyttöoikeudet ja salasanaolitiikka	Onko salasanaolitiikka määritelty (pituus, monimutkaisuus, uusiminen)?	ISO 27002, Traficom		
Käyttöoikeudet ja salasanaolitiikka	Onko käyttöoikeudet rajattu vain tarpeellisiin (least privilege)?	NIST CSF		
Varmuuskopiointi ja jatkuvuus	Onko varmuuskopiointikäytännöt määritelty ja dokumentoitu?	ISO 27002, Traficom		
Varmuuskopiointi ja jatkuvuus	Onko palautustestaus tehty viimeisen 12 kk aikana?	NIST SP 800-34, Traficom		

Varmuuskopiointi ja jatkuvuus	Onko jatkuvuussuunnitelma olemassa (toipuminen häiriöistä, esim. ransomware)?	NIST CSF, ISO 27031		
Seuranta ja raportointi	Onko tietoturvapolitiikan noudattamista seurattu?	ISO 27001		
Seuranta ja raportointi	Onko poikkeamista tehty raportteja johdolle?	ISO 27001		
Seuranta ja raportointi	Onko auditoinnin tuloksia hyödynnetty kehitystoimissa?	NIST CSF		